SITAA — Project Design Document

Critical Review: Problems, Gaps & Inconsistencies

Challenge	Contactless Fingerprint Authentication
Document	Project Design Document v1.0
Review date	30 May 2026
Scope	Technical, security, compliance and completeness review of the PDD prior to MSH submission

How to read this report

Each problem is rated by severity and split into **Group A** (objective inconsistencies that are hard to dispute — fix these first), **Groups B–E** (technical, security and compliance concerns an expert reviewer is likely to raise), and **Group F** (items missing relative to the project's own stated goals). Severity reflects the risk to a successful pilot evaluation, not the effort to fix.

HIGH Likely to be challenged hard / blocks credibility

MED Should be addressed before submission

LOW Polish / completeness

Summary

Group	Theme	Items	Highest severity
A	Internal inconsistencies (factual)	4	MED
B	Domain-mismatch / validation gaps	4	HIGH
C	Architecture feasibility	4	HIGH
D	Security / cryptography	3	MED
E	Compliance / spec questions	3	MED
F	Missing items vs stated goals	2	MED

Priority guidance: lead with Group A (quick objective fixes), then proactively address B5, B6, C9 and C11 in the narrative — these four (PAD domain mismatch, contactless TAR realism, the TEE-inference claim, and entry-level camera macro-focus feasibility) are the points an expert evaluator will hit hardest. Getting ahead of them reads as competence rather than a gap.

Group A — Internal Inconsistencies (Factual)

#1	U2-Net size contradicts itself	MED
Where	§2.1 Layer 3 vs §2.3 model table	
Problem	Layer 3 describes U2-Net as a “lightweight U2-Net model (1.8 MB INT8-quantised)”, but the technology-stack table lists U2-Net at **~4.7M parameters**.	
Why it matters	A 4.7M-parameter model quantised to INT8 is approximately 4.7 MB, not 1.8 MB, and 4.7M parameters is not credibly “lightweight”. A reviewer comparing the two pages will see a numbers mismatch and question the rest of the model-size figures.	
Recommended fix	Decide on one authoritative figure. If you are using the small variant (U2-Netp, ~1.1M params) say so; otherwise correct either the 1.8 MB or the 4.7M figure so they are internally consistent.	

#2	Minimum API 21 conflicts with NNAPI / Hexagon reliance	MED
Where	§2.3 SDK Distribution vs ML Runtime	
Problem	The SDK claims a **minimum API level of 21 (Android 5.0)**, while the ML runtime is “TensorFlow Lite with NNAPI delegate (Hexagon DSP, Adreno GPU)”.	
Why it matters	The NNAPI delegate requires API 27+, and robust DSP/Hexagon acceleration requires newer versions still. On API 21–26 the pipeline silently falls back to CPU and the 2.0-second latency budget is no longer achievable. Advertising an API-21 floor for a hardware-accelerated biometric pipeline is misleading even with the “certified for API 28+” caveat.	
Recommended fix	State a realistic functional floor for the accelerated path (e.g. API 27/28) and describe exactly what the SDK does on lower API levels (reject, or CPU fallback with a stated latency penalty).	

#3	Timeline, team and governance sections are blank	MED
Where	§1.4, §2.4, §3.1, §3.2, §3.4, Appendices A–D	
Problem	Milestones M1–M5 all read “Week ___”; Stakeholder Mapping (§1.4), Team Structure (§3.1), Resource Adequacy (§3.2) and Governance (§3.4) are empty; Appendices A–D are all unchecked / not attached.	
Why it matters	As submitted, the document has no committed schedule, no named team, and no governance cadence. Evaluators read empty planning sections as low execution readiness, regardless of how strong the technical sections are.	
Recommended fix	Fill in concrete target weeks, named roles, hardware/infrastructure/partner lines, a reporting cadence and escalation path, and attach (or mark a dated plan for) Appendices A–D before submission.	

#4	DSA signing is under-specified and an unusual choice	MED
Where	§2.1 Layer 5 & §4.1	
Problem	The design specifies a “DSA signature of the biometric hash” with a device-specific key, but gives no key size and chooses DSA over RSA/ECDSA.	
Why it matters	For Aadhaar device attestation, DSA is an unusual selection; it also fails catastrophically (private-key recovery) if the per-signature nonce is ever reused or weakly generated. An unspecified key size invites a follow-up question.	
Recommended fix	Either justify DSA against the Aadhaar device-key specification and state the key size and nonce-generation guarantee, or switch to ECDSA/RSA in line with the rest of the crypto stack.	

Group B — Domain-Mismatch & Validation Gaps

#5	Passive PAD is trained/evaluated on the wrong domain	HIGH
Where	§2.1 Layer 2; §1.3 KR 5	
Problem	The passive PAD is a MobileNetV3-Small “trained and evaluated on LivDet-Fingerprint 2023”, and the spoof-resistance KR (APCER < 5% / BPCER < 3%) is implicitly drawn from it.	
Why it matters	LivDet-Fingerprint is a **contact-sensor** spoof corpus. Your attack surface is a **contactless camera** (printed photo or screen replay held in front of the lens, 3D molds at a distance). The spoof textures, optics and artefacts are entirely different, so LivDet-derived APCER/BPCER numbers do not transfer. This is the single easiest point for an evaluator to attack.	
Recommended fix	Collect or cite a contactless PAD dataset, or explicitly label the current numbers as a contact-domain baseline with a plan to revalidate on contactless attacks during M4. Do not present LivDet numbers as the pilot KR without that caveat.	

#6	90% TAR is a contact-based extrapolation against a contact gallery	HIGH
Where	§1.3 KR 1; §2.1 Layer 4	
Problem	The headline accuracy KR is TAR ≥ 90% at FAR 0.01%, flagged as “extrapolated from contact-based benchmarks” to be revalidated at M4.	
Why it matters	The real task is matching a **contactless probe against the authority’s contact-based gallery**. Cross-domain (contactless-to-contact) matching in the published literature typically sits well below 90% at FAR 0.01%. Even with the asterisk, stating 90% invites the “unrealistic target” critique and sets up the pilot to look like a miss.	
Recommended fix	Frame the 90% explicitly as a contact-to-contact reference, set a separate, evidence-based contactless-to-contact target band, and describe the C2CL domain-adaptation step as the mechanism to close the gap.	

#7	NFIQ2 ≥ 60 applied to contactless captures	MED
Where	§1.3 KR 2; §2.1 Layer 3 step 7	
Problem	Capture-quality KR requires an NFIQ2 surrogate score ≥ 60 on > 85% of accepted captures, using an on-device MobileNetV3 surrogate correlated against NFIQ2 offline.	
Why it matters	NFIQ2 is defined and validated for 500 DPI grayscale **contact** fingerprints. Applying it (even via a surrogate) to rectified contactless imagery is methodologically questionable, and ≥ 60 on > 85% of captures is aggressive for camera-based acquisition.	
Recommended fix	Acknowledge the NFIQ2 contactless limitation, report the surrogate-to-NFIQ2 correlation you actually achieve, and consider a contactless-appropriate quality target rather than a borrowed contact threshold.	

#8	Interoperability validated with proxy matchers, not the real AFIS	MED
Where	§2.3 Interoperability Targets; §4.1	
Problem	Cross-sensor interoperability is validated using SourceAFIS and BOZORTH3 against the Mantra MFS100 and Startek FM220U, supplemented by NIST BIOMDI conformance.	
Why it matters	The production matcher is the authority’s proprietary AFIS. Good scores on open-source matchers do not guarantee equivalent behaviour on AFIS, so the validation methodology is a proxy that may not predict the outcome that actually matters.	
Recommended fix	Keep the open-matcher validation as an early signal, but state clearly that it is a proxy, and make AFIS sandbox validation an explicit M4 dependency with a fallback plan if sandbox access is delayed.	

Group C — Architecture Feasibility

#9	“Layers 4 & 5 run inside the hardware TEE” is not realistic	HIGH
Where	§2.1 Layers 4–5; §2.2 Privacy-by-Design	
Problem	The target production architecture claims that template generation (Layer 4 — LEADER, U2-Net, TFLite inference) and the security layer execute “within the device’s hardware TEE”.	
Why it matters	Commodity Android TEEs (TrustZone) have very limited memory and compute and provide no TFLite/NNAPI runtime. You cannot run a U2-Net / LEADER inference graph inside the TEE — TEEs are for key storage and crypto operations only. As written, this claim suggests a misunderstanding of the platform and will draw a pointed question.	
Recommended fix	Scope the TEE to Layer 5 cryptographic / signing operations only. Describe Layer 4 inference as running in the app’s native sandbox with in-memory-only buffers, and keep the “never persisted” privacy guarantee at that level.	

#10	MediaPipe hand-landmark liveness conflicts with close-up ridge capture	HIGH
Where	§2.1 Layer 1 vs Layer 3	
Problem	Layer 1 uses MediaPipe Hand Landmarks for finger-in-frame detection, palm/dorsal checks and gesture liveness, while Layer 3 needs ~500 DPI-equivalent ridge detail.	
Why it matters	To resolve ridges you must fill the frame with the fingertip; but MediaPipe Hand Landmarks needs the **whole hand** visible to produce reliable landmarks and palm/dorsal classification. A close fingertip crop defeats the hand tracker, and a hand-distance framing defeats ridge resolution. The two requirements are in direct tension and the document never reconciles them.	
Recommended fix	Define the capture choreography explicitly: e.g. a hand-distance liveness/landmark phase followed by a guided zoom-in capture phase, or a fingertip-only liveness method, and show the two phases fit the latency and UX budget.	

#11	Entry-level camera macro-focus feasibility is not treated as a risk	HIGH
Where	§3.3 Risk table (omission); §4.2 Device Coverage	
Problem	Tier-3 targets are Snapdragon 439 / Helio G35-class phones, yet the risk table contains no entry on whether such cameras can focus closely enough to resolve fingerprint ridges.	
Why it matters	This is arguably the core technical risk of the entire concept. Budget-phone rear cameras often have a minimum focus distance that prevents sharp macro capture of a fingertip, producing blur that no downstream enhancement can recover. Its absence from the risk register is conspicuous.	
Recommended fix	Add an explicit risk row for capture resolution / macro-focus on entry-level cameras, with a mitigation (minimum-camera-spec gating, guided distance, multi-frame fusion) and a measurement plan during M3/M4.	

#12	The ~737 ms critical path is projected and optimistic	MED
Where	§2.1 Layer 3 step 3; §3.3 latency risk	
Problem	The 737 ms fast-path figure is explicitly “derived from component-level benchmarks” and LEADER is assumed to run in ~100 ms on a Hexagon DSP.	
Why it matters	Component-level sums routinely understate end-to-end latency (camera, MediaPipe, copies, JNI boundaries). Custom INT8 operators frequently fall back from the DSP to CPU/GPU on mid-range SoCs, inflating the 100 ms figure. The stated “>50% margin” is therefore theoretical until M3.	
Recommended fix	Label the 737 ms clearly as a projection, list the DSP-op-support assumption, and commit to an end-to-end measured figure on a real Snapdragon 680 device as an M3 exit criterion.	

Group D — Security & Cryptography

#13	AES-GCM IV derived deterministically from the timestamp	MED
Where	§2.2 Encryption	
Problem	The IV is “derived from the last 12 bytes of the PID transaction timestamp” for AES-256-GCM, with AAD from the last 16 bytes of the timestamp.	
Why it matters	GCM security collapses if a (key, IV) pair is ever reused. It is probably safe here because a fresh session key is generated per transaction, but a deterministic, low-entropy, attacker-predictable IV is a smell that a security reviewer will challenge.	
Recommended fix	Either state explicitly that the per-transaction fresh key guarantees (key, IV) uniqueness, or use a cryptographically random 96-bit IV. If the timestamp derivation is mandated verbatim by the Aadhaar RD specification, cite that clause.	

#14	RSA-2048 uses PKCS#1 v1.5 padding	MED
Where	§2.2 Encryption	
Problem	Session-key wrapping uses RSA-2048 with “ECB/PKCS1Padding”.	
Why it matters	PKCS#1 v1.5 is the legacy padding associated with Bleichenbacher-style padding-oracle attacks; OAEP is the modern best practice. If this is not a hard mandate it will be flagged.	
Recommended fix	If the authority mandates PKCS#1 v1.5, cite the specification clause explicitly so it reads as compliance, not a design choice; otherwise move to RSA-OAEP.	

#15	Software Keystore pilot undercuts the L1 attestation story	MED
Where	§2.2 Anti-Tamper; §4.1 RD Service Compatibility	
Problem	The design claims a three-tier PKI chain (Authority Root → Device Provider → Device Key) plus anti-tamper (root/Frida detection, OLLVM, Play Integrity), while the pilot keys live in **software** Android Keystore.	
Why it matters	On a rooted device, software-held keys and detection heuristics are bypassable, so the pilot “device key” is not a genuine hardware-rooted registered-device identity. The disclosure is honest, but the surrounding language risks over-claiming L1-grade security for the pilot.	
Recommended fix	Clearly separate “pilot security posture (software, best-effort)” from “production L1 posture (hardware TEE / StrongBox)”, and avoid implying the pilot already provides device-bound hardware attestation.	

Group E — Compliance & Specification Questions

#16	Sending Bio type FIR (image) for authentication is unusual	MED
Where	§1.2; §2.3 Interoperability	
Problem	The PID block carries both FIR (ISO 19794-4 image record) and FMR (ISO 19794-2 minutiae record).	
Why it matters	Aadhaar authentication has historically processed **FMR minutiae** from registered devices; pushing a full image record (FIR) for a 1:1 auth transaction is unusual, larger on the wire, and may not be accepted by the Auth API for the authentication (as opposed to enrolment) use case.	
Recommended fix	Confirm against Aadhaar Authentication API v2.5 that FIR is accepted for the auth use case; if not, default to FMR for auth and reserve FIR for enrolment / interoperability testing.	

#17	DPDP consent is delegated to the host app the SDK cannot control	MED
Where	§2.2 Compliance (DPDP Act 2023)	
Problem	Consent is “collected via … the host application’s UX flow”, and consent withdrawal is exposed as an SDK API.	
Why it matters	Because the SDK ships to third-party host applications, it cannot itself guarantee that valid, purpose-specific consent was obtained — that responsibility is delegated. On paper this leaves a DPDP compliance gap unless the integrator’s obligations are contractually defined.	
Recommended fix	Spell out the consent and retention obligations you contractually place on integrators, and describe any SDK-side enforcement (e.g. a required consent token before capture initiation).	

#18	“Post-template plausibility check” is undefined	LOW
Where	§3.3 Risk mitigation vs §2.1 Architecture	
Problem	A “post-template plausibility check as an additional gate” appears only in the spoof-attack risk mitigation, but no such component exists in the Layer 1–6 architecture.	
Why it matters	Introducing a security control in the risk table that is absent from the architecture looks like a retrofit and invites a “where is this implemented?” question.	
Recommended fix	Either define the plausibility check as a named sub-stage (likely within Layer 4 or 5) or remove the reference from the risk mitigation.	

Group F — Missing Items vs Stated Goals

#19	No fairness or Failure-to-Enrol/Acquire metric despite headline inclusion claims	MED
Where	§1.3 OKR table vs §1.2 / §4.4	
Problem	“Demographic Fairness” and inclusion (worn prints, elderly, Fitzpatrick V–VI) are headline priorities, yet the five OKRs contain no demographic-breakdown metric and no FTE/FTA rate.	
Why it matters	The document claims inclusion benefits but never commits to measuring them. An evaluator focused on public value will note that the central social claim has no corresponding key result.	
Recommended fix	Add a per-subgroup TAR / FTA key result (e.g. worn-fingerprint and elderly cohorts) and a failure-to-acquire target, so the fairness claim is measurable.	

#20	Active-liveness gesture is in tension with inclusion and the latency framing	LOW
Where	§1.3 KR 4; §2.1 Layer 1	
Problem	Active liveness uses a gesture challenge-response, while KR 4 specifies ≤ 2.0 s “end-to-end” latency and §4.4 promises easy capture for elderly / limited-mobility users.	
Why it matters	Gesture challenge-response adds user interaction time and friction that work against the limited-mobility and elderly inclusion claims, and that wall-clock time is not part of the 2.0-second budget (which covers processing only). The “end-to-end” wording is therefore ambiguous.	
Recommended fix	Clarify precisely what the 2.0-second figure covers (processing vs total user-perceived time) and offer a reduced-friction liveness path for accessibility cohorts.	

Suggested Submission Strategy

1. Fix Group A immediately. These are objective inconsistencies (model size, API floor, blank planning sections, DSA spec). They cost little to correct and their presence undermines confidence in the more

sophisticated sections.

2. Get ahead of the four hardest objections. In the narrative, proactively address the PAD domain mismatch (B5), contactless-to-contact TAR realism (B6), the TEE-inference claim (C9), and entry-level camera macro-focus feasibility (C11). Raising these yourself, with a measurement plan, signals engineering maturity.

3. Reframe, don't hide, the pilot's software-security posture. Cleanly separate the software-Keystore pilot from the hardware-TEE production target (D15, C9) so you never appear to over-claim L1-grade guarantees.

4. Make the social claims measurable. Add a fairness / FTE key result (F19) so the inclusion story has evidence behind it.

This review is a constructive critique intended to strengthen the PDD before MSH submission. It does not assess the underlying technology's merit, only the document's internal consistency, technical defensibility, and completeness.